

# Pilot-checklista — CVmatchen × Helsingborg AMF

---

Pilot: Ungdoms-/Kompetensarena · ca 20–40 deltagare · 3–4 handläggare · 3 månader, kostnadsfritt · Uppdaterad: 2026-07-10

Ägare: **[D]** = Oliver/du · **[K]** = kommun (chef/verksamhet) · **[DSO]** = dataskyddsombud · **[J]** = jag (kod)

---

## MÅSTE vara klart innan första riktiga deltagardata

### Juridiskt & organisatoriskt

- ☐ **PUB-avtal signerat** av båda parter (du för PathfinderAI, behörig kommunföreträdare för PUA — inte du i SYV-rollen) · **[D]+[K]**
- ☐ **Pilotbeslut fattat och diariefört av kommunen** (din chef/ verksamhetschef — inte du), skilt från den generella bisysslan · **[K]**
- ☐ **DPIA godkänd av DSO** · **[DSO]**
- ☐ **Laglig grund för ev. art. 9-uppgifter fastställd** · **[DSO]**
- ☐ **Lagringstid fastställd** (förslag: radering vid pilotens slut) · **[DSO]**

### Tekniskt

- ☐ **Accept-invite-token-flödet** klart (i dag "dekorativ" token — blocker #9) · **[J]**
  - ☐ **Mejlleverans verifierad** (invite → deltagare via Resend) · **[D]+[J]**
  - ☐ **Invite-kedjan testad end-to-end** (bjud in → OTP → CV → uppgift) · **[D]+[J]**
- 

## Redan klart

- ☒ GDPR-radering ( `admin_delete_user` + `user_delete_self` , kaskad 13 tabeller + auth)
  - ☒ AI-samtycke live (versionerat, återkalleligt)
  - ☒ Bedrock-EU aktiv (AI-data stannar i Frankfurt)
  - ☒ Varningstext mot känsliga uppgifter i fritext (art. 9)
  - ☒ DEMO\_MODE av i produktion
  - ☒ Multi-tenant-isolation (serverside verifyAdmin, deny-by-default)
  - ☒ XSS-fixar + OAuth-callback-säkerhet (host-header, CSRF)
  - ☒ Bisyssla prövad och godkänd av HR (undertecknat beslut)
  - ☒ PUB- och DPIA-utkast framtagna (Helsingborg-specifika)
  - ☒ Verifieringsrapport (hemlighetsscan, beroende-scan, a11y-scan)
  - ☒ a11y: aria-label på alla synliga kontroller
  - ☒ Lasttest-script ( `tests/load-test.js` )
- 

## Bör fixas tidigt (ej blockerande)

[ ] **Rotera de två flaggade API-nycklarna** ( SUPABASE\_SERVICE\_KEY + ANTHROPIC\_API\_KEY ) — ~5 min · **[D]** (backlog #34)

[ ] Döp om WS\_BEARER\_TOKEN\_BEDROCK → AWS\_BEARER\_TOKEN\_BEDROCK i Vercel · **[D]** (backlog #33)

[ ] Onboarding-guide för handläggare (första-gångs-vy) · **[J]** (#11)

[ ] Mobil-layout i handläggare-vyn · **[J]** (#12)

[ ] Rate-limiting på admin-endpoints · **[J]** (#19)

[ ] Pilot-utgångsbanner när < 14 dagar kvar · **[J]** (#13)

[ ] "Skicka om invite"-knapp · **[J]** (#14)

---

## Kan vänta till efter pilotstart

[ ] Puppeteer-uppgradering (23 dep-sårbarheter, kräver PDF-test) · **[J]** (#35)

[ ] Statistik-export som CSV · **[J]** (#22)

[ ] AI-SYV-chatt som pratbubblor · **[J]** (#S4)

[ ] Capacitor-app (App Store/Google Play + push) · **[J]** (#S3)

[ ] Extern pentest + WCAG-audit (finansieras via Visionsfonden) · **[D]**

---

## Parallella spår

[ ] **Visionsfonden-ansökan** (öppnar september 2026) — finansierar pentest + WCAG-audit · **[D]** (#S1)

[ ] Effektuppföljning under piloten (deltar/slutför/upplevd nytta) — ger beslutsunderlag + underlag till Visionsfonden · **[D]+[J]**

---

## Rekommenderad ordning

1. **[K]** Pilotbeslut diariefört + **[D]/[K]** PUB signerat + **[DSO]** DPIA godkänd → grön juridik.
2. **[J]** Bygg klart accept-invite-token (#9) → sista tekniska blockerna.
3. **[D]+[J]** Testa invite-kedjan + mejllleverans med ett testkonto.
4. **[D]** Rotera nycklarna (#34).
5. Bjud in första riktiga deltagaren. 🚀